

Презентация (Криптография на практике)

Асимметричная криптография. Хэш-функции. Цифровая подпись. Платежи. Блокчейн

Асимметричные криптографические примитивы

В асимметричной криптографии у каждой стороны есть своя пара ключей: - открытый (публичный) ключ – передаётся другой стороне - закрытый (секретный) ключ – хранится в тайне

При обмене данными: 1. Одна сторона шифрует открытым ключом другой 2. Другая сторона расшифровывает своим закрытым ключом

Свойства криптографической хэш-функции

Основные свойства: - стойкая к коллизиям – невозможно найти два разных входных блока с одинаковым хэшем - эффективно вычисляется – хэш можно быстро посчитать для любых входных данных - фиксированное число бит на выходе – SHA-256 всегда даёт 256 бит

Хэш-функция НЕ обеспечивает конфиденциальность данных (не шифрует).

Алгоритмы цифровой подписи

К алгоритмам цифровой подписи относятся: - RSA (RSA-PSS, RSASSA-PKCS1-v1_5) - ECDSA (на эллиптических кривых) - ГОСТ Р 34.10-2012 (российский стандарт)

Не являются алгоритмами цифровой подписи: - AES (симметричное шифрование) - SHA2 (хэш-функция, используется в схемах подписи, но сама по себе не подпись)

Код аутентификации сообщения (MAC)

MAC (Message Authentication Code) относится к симметричным примитивам.

Особенности MAC: - один секретный ключ для вычисления и проверки метки - ключ известен и отправителю, и получателю

Асимметричные примитивы для аутентификации используют цифровую подпись (разные ключи для подписи и проверки).

Обмен ключами Диффи-Хэллмана

Диффи-Хэллман – это асимметричный примитив генерации общего секретного ключа.

Как работает: - стороны обмениваются открытыми компонентами (публичными ключами) через незащищённый канал - каждая сторона использует свой секретный ключ - на выходе получается общий секретный ключ для симметричного шифрования

Не является: симметричным примитивом, алгоритмом шифрования, генерацией общего открытого ключа.

Протокол электронной цифровой подписи

ЭЦП относится к протоколам с открытым (публичным) ключом.

Принцип: - подпись создаётся секретным (закрытым) ключом - подпись проверяется открытым (публичным) ключом

Отличие от симметричных протоколов: в симметричных один и тот же ключ используется и для создания, и для проверки.

Верификация цифровой подписи

Алгоритм верификации требует на вход: - подпись (то, что создал отправитель) - сообщение (к которому привязана подпись) - открытый ключ отправителя

Секретный ключ при верификации не используется – он нужен только для создания подписи.

Что не обеспечивает цифровая подпись

ЭЦП обеспечивает: - целостность – подпись не совпадёт при изменении сообщения - аутентификацию – можно установить, кто подписал - неотказ от авторства – отправитель не сможет отрицать подпись

ЭЦП НЕ обеспечивает конфиденциальность (защиту от прочтения третьими лицами).

Для конфиденциальности сообщение нужно дополнительно шифровать.

Сертификат для отправки отчётности в ФНС

Для отправки отчётности в госорганы (ФНС, ПФР, Росстат) требуется усиленная квалифицированная электронная подпись (КЭП).

Требования к КЭП: - создаётся с помощью средств криптографической защиты (СКЗИ) - сертифицирована ФСБ - ключи проверки содержатся в квалифицированном сертификате

Простая подпись и усиленная неквалифицированная не подходят.

Где получить квалифицированный сертификат

Квалифицированный сертификат можно получить только в удостоверяющем (сертификационном) центре.

Требования к УЦ: - аккредитация - лицензия ФСБ на выпуск сертификатов ключей проверки электронных подписей

Не подходят: любая организация с лицензией ФСБ, минкомсвязи РФ, любая организация по месту работы.

Платёжные системы

Платёжная система – совокупность правил и инфраструктуры для переводов денег между участниками.

Примеры платёжных систем: - MasterCard (международная) - МИР (национальная платёжная система России)

Не являются платёжными системами: Bitcoin (криптовалюта), SecurePay (платёжный шлюз), POS-терминал (устройство), банкомат (устройство).

Многофакторная аутентификация (MFA)

MFA использует два и более факторов из разных категорий:

Категории факторов: - знание – пароль, PIN-код - владение – телефон (SMS-код), токен, карта - свойство – отпечаток пальца, Face ID, голос

Примеры MFA: - пароль + код из SMS (знание + владение) - код из SMS + отпечаток пальца (владение + свойство)

Не MFA: пароль + капча (капча не фактор аутентификации), PIN-код + пароль (оба – знание).

Онлайн-платежи: аутентификация

При онлайн-платежах используется многофакторная аутентификация покупателя перед банком-эмитентом.

Стандарт: 3D Secure (Verified by Visa, Mastercard SecureCode, Мир Accept).

Как работает: - покупатель подтверждает платёж паролем из SMS или через приложение банка - факторы: знание пароля + владение телефоном

Банк-эмитент – банк, выпустивший карту.

Proof of Work (доказательство работы)

В Proof of Work используется свойство хэш-функции: сложность нахождения прообраза (pre-image resistance).

Задача майнера: найти попсе, чтобы хэш заголовка блока был меньше целевого порога (начинался с определённого количества нулей).

Зная хэш, невозможно быстро подобрать входное значение (только полный перебор).

Другие свойства хэш-функции не являются основой PoW.

Свойства консенсуса в блокчейне

Консенсус в блокчейне обладает свойствами: - живучесть (liveness) – система продолжает работать, новые блоки добавляются - постоянства (finality) – подтверждённые данные необратимы - открытость – любой может присоединиться к сети, участвовать в валидации

Сам процесс согласования называется консенсусом, но это не свойство, а механизм.

Секретные ключи в блокчейне

Участники блокчейна хранят секретные ключи для цифровой подписи.

Закрытый ключ используется для: - создания подписи под транзакцией - подтверждения, что владелец ключа разрешает перевод

Открытый ключ (или адрес из него) используется для: - проверки подписи - идентификации получателя

Другие примитивы (обмен ключами, шифрование, хэш-функции) не требуют хранения секретных ключей участниками для базовых операций блокчейна.